

Manual 53 — Privacidade de IA e Governança de Dados

Fonte controlada de publicação — português do Brasil

Data de verificação: 1 de setembro de 2026

Estado de liberação: fonte candidata

Objetivo

Este manual estabelece um modelo operacional prático de privacidade e governança de dados para sistemas de IA, incluindo aprendizado de máquina convencional, IA generativa, RAG/armazenamentos vetoriais e sistemas agênticos. Ele apoia a implementação empresarial sem transformar obrigações jurídicas específicas de cada jurisdição em uma única regra genérica de privacidade.

Disciplina sobre o status das fontes

O NIST Privacy Framework é orientação voluntária. Nesta edição, o Privacy Framework 1.1 continua como projeto Initial Public Draft e não é apresentado como substituto final do PF 1.0. Leis, orientações regulatórias e obrigações contratuais de cada jurisdição mantêm sua própria aplicabilidade, definições, direitos, prazos e status de fiscalização. Um controle empresarial comum pode apoiar vários regimes, mas não os torna equivalentes.

Modelo operacional de privacidade e dados

Caso de uso → fonte de dados → autorização/finalidade → ingestão → pré-processamento → treinamento/ajuste → limite do modelo/provedor → prompt/contexto → RAG/armazenamento vetorial → ferramentas/APIs → saída → logs/telemetria → retenção/exclusão → evidência de direitos/incidentes/mudanças.

PD-01 — Uso autorizado e limitação de finalidade

Documentar finalidade de negócio, base jurídica ou autorização aplicável, restrições de origem, compatibilidade do uso e responsável antes de utilizar dados em treinamento, ajuste, RAG, avaliação, monitoramento ou inferência de produção.

PD-02 — Inventário, proveniência e linhagem de dados

Manter inventário rastreável de conjuntos de dados, prompts, corpus, embeddings, armazenamentos vetoriais, dados de feedback, conjuntos de avaliação e dados mantidos por provedores. Registrar fonte, proprietário, base de aquisição, transformações, usos posteriores e restrições materiais.

PD-03 — Minimização e limitação de coleta

Limitar dados pessoais, confidenciais e sensíveis ao necessário para a finalidade aprovada. Avaliar atributos de menor risco, agregação, mascaramento, dados sintéticos ou retenção menor quando permitirem atingir o objetivo.

PD-04 — Dados sensíveis e categorias especiais

Identificar dados sensíveis, categorias especiais, biométricos, saúde, financeiros, localização precisa, crianças e outros dados protegidos conforme os regimes aplicáveis. Aplicar autorização, acesso, minimização, testes e escalonamento reforçados quando necessário.

PD-05 — Qualidade e representatividade dos dados

Definir critérios de adequação à finalidade, limitações conhecidas, dados ausentes, viés de amostragem, qualidade de rótulos e deriva. Preservar evidência de que as decisões de qualidade foram adequadas ao caso de uso e às populações afetadas.

PD-06 — Governança de dados de treinamento e ajuste

Controlar dados de treinamento, fine-tuning e feedback por meio de fontes aprovadas, proveniência, revisão de direitos/autorização, versionamento, integridade, retenção e procedimentos de remoção. Distinguir configurações de melhoria de modelo do provedor de treinamento controlado pela organização.

PD-07 — Limites de RAG e armazenamento vetorial

Governar aprovação do corpus, proveniência documental, embeddings, filtros por função/tenant, acesso ao armazenamento vetorial, política de recuperação, fontes obsoletas e propagação de exclusão. Recuperar um documento não comprova que seu uso seja autorizado ou correto.

PD-08 — Autorização de recuperação e isolamento

Avaliar autorização no momento da recuperação, não apenas na ingestão. Impedir recuperação entre tenants, funções ou finalidades e testar injeção indireta e exfiltração iterativa que possam revelar dados além da autorização do usuário.

PD-09 — Retenção e exclusão

Definir regras para dados de origem, prompts, saídas, logs, embeddings, armazenamentos vetoriais, caches, backups e cópias mantidas pelo provedor. Verificar propagação de exclusão e documentar limitações técnicas quando a exclusão imediata não for viável.

PD-10 — Transferências internacionais e residência

Mapear origem, local de processamento, cadeia de provedores/subprocessadores, armazenamento e mecanismo de transferência quando aplicável. Preservar avaliações e salvaguardas específicas de cada jurisdição sem assumir que um controle global satisfaz todos os regimes.

PD-11 — Suporte aos direitos das pessoas

Quando aplicável, apoiar acesso, correção, exclusão, oposição, restrição, recurso ou direitos semelhantes. Analisar implicações para modelo, treinamento, RAG, logs e provedores e registrar quando uma solicitação não puder ser atendida técnica ou juridicamente como apresentada.

PD-12 — Transparência e avisos de privacidade

Fornecer avisos precisos sobre usos relevantes de dados, processamento de IA, envolvimento de provedores, retenção, decisões automatizadas ou apoiadas por IA e escolhas materiais quando exigido. Não afirmar que todo uso de IA requer o mesmo mecanismo de aviso ou consentimento.

PD-13 — Integração de DPIA/PIA

Aplicar avaliações de impacto de privacidade quando exigidas ou adequadas ao risco. Documentar pessoas afetadas, necessidade/proporcionalidade quando aplicável, fluxos de dados, ameaças, mitigação, risco residual, consultas, aprovações e gatilhos de reavaliação.

PD-14 — Integração com avaliação de impacto/risco de IA

Compartilhar evidências entre avaliações de privacidade e risco de IA mantendo critérios de decisão separados. Relacionar danos à privacidade, equidade, ameaças de segurança, supervisão humana, explicabilidade e impactos operacionais sem substituir uma avaliação pela outra.

PD-15 — Desidentificação e risco de reidentificação

Validar alegações de anonimização, desidentificação, pseudonimização ou agregação diante de riscos realistas de vinculação e inferência. Não tratar dados transformados como automaticamente fora do escopo de privacidade sem análise jurídica e técnica sustentável.

PD-16 — Logging e observabilidade com preservação de privacidade

Coletar telemetria suficiente para segurança, qualidade e responsabilização minimizando conteúdo pessoal ou sensível desnecessário. Definir redação, acesso, retenção, identificadores de correlação e regras de preservação para incidentes.

PD-17 — Governança de dados de terceiros e provedores de modelos

Avaliar papéis do provedor, uso de prompts/saídas, configurações de melhoria do modelo, subprocessadores, hospedagem, retenção, segurança, incidentes, evidência de auditoria, transferências e requisitos de saída/exclusão. Reconciliar contratos com a configuração técnica real.

PD-18 — Incidentes e violações de privacidade

Preservar dados afetados, pessoas, sistemas, versões de modelo/provedor, prompts, eventos RAG, identidades e evidência de contenção. Realizar análise de notificação específica por jurisdição e integrar incidentes de privacidade à resposta de segurança e IA.

PD-19 — Gestão de mudanças e reavaliação

Acionar reavaliação diante de novas fontes, finalidades, jurisdições, modelos/provedores, corpus RAG, ferramentas, permissões, configurações de retenção ou mudanças materiais de processamento. Registrar aprovação, testes e disposição do risco residual.

PD-20 — Garantia, auditoria e reporte gerencial

Testar evidência de implementação, fluxos de direitos, exclusão, limites de recuperação, controles de provedores, qualidade das avaliações e exceções. Reportar riscos residuais

materiais, remediações vencidas, incidentes, problemas de transferência e falhas recorrentes.

Cenários práticos

Cenário 1 — Assistente GenAI global com RAG interno

Rastrear proveniência documental, sensibilidade de dados, limites de acesso, retenção de embeddings/vetores, restrições de treinamento do provedor, hospedagem internacional, propagação de exclusão e logs de recuperação. Separar evidência empresarial comum de obrigações específicas por jurisdição.

Cenário 2 — Modelo treinado com dados históricos de clientes

Validar finalidade original, autorização, minimização, dados sensíveis, retenção, representatividade, alegações de desidentificação e riscos posteriores. Determinar se retreinamento, exclusão ou remoção são tecnicamente e juridicamente necessários após retirada da fonte ou exercício de direitos.

Cenário 3 — Decisão de emprego apoiada por IA

Combinar análise de privacidade/trabalhista, avaliação de impacto de IA, minimização, atributos sensíveis ou inferidos, revisão humana, explicação/recurso, retenção e responsabilização do provedor.

Cenário 4 — Provedor externo de modelo fundacional

Documentar papel do provedor quando aplicável, uso de prompts/saídas, subprocessadores, hospedagem, retenção, segurança, incidentes, melhoria do modelo e requisitos de saída/exclusão.

Cenário 5 — Nova jurisdição adicionada após implantação

Acionar revisão de aplicabilidade, transferências, avisos/direitos, retenção local, localização do provedor e nova aprovação antes de ampliar o uso quando exigido.

Registro de evidências

- PD-E01 Inventário de dados de IA.
- PD-E02 Registro de proveniência e linhagem.
- PD-E03 Avaliação de uso autorizado e finalidade.
- PD-E04 DPIA/PIA e avaliação de impacto de IA.
- PD-E05 Registro de controles de dados sensíveis.
- PD-E06 Registro de governança RAG/vetor.
- PD-E07 Evidência de resposta a direitos.
- PD-E08 Avaliação de transferência internacional.
- PD-E09 Avaliação de dados de terceiros.
- PD-E10 Verificação de retenção/exclusão.
- PD-E11 Registro de incidente de privacidade.
- PD-E12 Registro de mudança/reavaliação.

Regra de liberação

Um controle de privacidade não é eficaz apenas porque existe uma política. A eficácia exige evidência de implementação, aplicabilidade qualificada por jurisdição, testes, tratamento de exceções e disposição do risco residual. Mudanças jurídicas, técnicas ou de provedor materiais exigem reavaliação.